SAVEETHA

INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Programme: **B.E / B.Tech**

Course Code: **ITA1439**

Course Name: **Ethical Hacking**

Duration: **1: 30 Hr**

Date: **02-11-2026**

Max Marks: **50 Marks**

43/50 & 86%

CONTINUOUS INTERNAL ASSESSMENT 1

Course Outcomes
On successful completion of the course, students will be able to:

CO	Course Outcome Statement
CO1	Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.
CO2	Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Answer all the Questions

1. A private bank hires a security firm to test its internet-banking portal before launch. In the same month, a former employee uses old credentials to view customer records, a student runs a downloaded attack tool against the portal "to see what happens", and an activist group defaces the bank's website. Define the term hacker and classify each person or group, including the hired testers, as white hat, black hat, grey hat, script kiddie, hacktivist or insider, with reasons. Explain the ethical principles the testers must follow, such as written authorization, agreed scope, confidentiality, avoiding harm and honest reporting. **(CO1) (BL3)**

2. A student finds an SQL injection flaw in the e-learning portal of another university that exposes the marks and contact details of about 20,000 students, without having permission to test it. The student is considering posting the details on social media, reporting privately to the university, or offering the details in exchange for payment. Analyze the legal position of the student under the Information Technology Act, 2000, with reference to unauthorized access and data theft. Compare full disclosure, responsible (coordinated) disclosure and bug-bounty programmes, and recommend the most appropriate disclosure process and timeline for this case with justification. **(CO1) (BL4)**

3. (a) A college authorizes its security club to carry out a penetration test of the student portal. Before any testing begins, the team must define how the engagement will be conducted. Apply the ethical-hacking methodology by listing its phases — reconnaissance, scanning, gaining access, maintaining access and reporting — and state the objective of each phase. Explain what a written rules-of-engagement / authorization document must specify (in-scope targets, time window, permitted and prohibited techniques, and the point of contact) to keep the engagement lawful, in-scope and non-destructive. **(CO1) (BL3) (5 Marks)**

(b) A security team is authorized to assess the internet exposure of a retail company that uses the domain retailco.example. Explain the difference between passive and active footprinting, and describe how the team would use WHOIS lookups, nslookup or dig, and search-engine operators (site:, filetype:, intitle:) to collect information about the company. For any THREE of these sources, state one item of information it may reveal and the security risk it creates. **(CO2) (BL3) (5 Marks)**

4. During an authorized assessment, a tester runs "dig axfr example.com @ns1.example.com" and the name server returns the full zone, including www (A, 203.0.113.10), vpn (A, 203.0.113.25), hr-portal (A, 10.10.5.20), dev-db (A, 10.10.8.15), mail (MX, priority 10) and a TXT record listing the SPF mail servers. Explain how a DNS zone transfer works and why it is meant only between primary and secondary name servers. Analyze what an attacker could learn from each record to plan further attacks, and recommend countermeasures such as restricting transfers, TSIG authentication and split-horizon DNS. **(CO2) (BL4)**

5. An organization receives an e-mail that appears to come from its IT help desk, asking employees to "verify" their passwords through a link. Later, a caller claiming to be from the help desk asks the accounts section for a one-time password, and a visitor without an ID card follows an employee through a secured door. Identify each attack type (phishing, vishing, pretexting or tailgating) and the psychological principles used, such as authority and urgency. Describe how an authorized social engineering assessment of this organization should be planned, and propose technical, procedural and awareness-based countermeasures. **(CO2) (BL3)**

CIA - 1.

R. Sathish
192324204.
ITA 1439.

1. Define hacker and classify different types of hackers. Explain the ethical principles followed by ethical hackers.

Introduction:

A hacker is a person who uses technical knowledge and computer skills to access, analyze or modify computer systems and networks. Hackers are classified based on their intentions and authorization.

Types of Hackers:

1. White Hat Hacker:

   Ethical hackers who work with proper permission.
   Identify vulnerabilities and improve system security.
   Example: Security testers hired by a bank.

2. Black Hat Hacker:

   Illegally access systems for malicious purposes.
   Steals confidential information or damage systems.
   Example: A person illegally accessing bank records.

3. Grey Hat Hacker:

   Access systems without permission by may not have malicious intentions.
   Identifies security weakness without authorization.

4. Script kiddie:

   Uses ready-make hacking tools without deep technical knowledge.

Example: A Student using a downloaded attack tool.

5. Hacktivist:

Uses hacking techniques to support political or Social causes.

Example: An activist group defacing a bank website.

Classification of Given Scenario:

Person	Classification	Reason
Hired security firm	White hat	Tests with permission.
Former employee	Insider	Misuses old Credentials.
Student.	Script kiddie	uses downloaded attack tools.
Activist group.	Hacktivist	Defaces the website.

Ethical Principles of Ethical Hacking:

1. Written Authorization: Obtain official permission before Starting Security testing.
2. Agreed Scope: Test only the approved systems and networks.
3. Confidentiality: Protect sensitive information such as customer records and passwords.
4. Avoiding Harm: Do not damage systems or interrupt normal services.
5. Honest Reporting: Report all Vulnerabilities accurately.
6. Legal Compliance: Follow cybersecurity laws and Organizational policies.

nclusion:

Ethical hackers help organizations identify security weakness and protect their systems while following legal and ethical principles.

2. Analyze the legal position Under the Information Technology Act, 2000. Compare disclosure methods and recommend the appropriate process.

Introduction:

SQL injection is a web security Vulnerability that allows attackers to manipulate database queries and access sensitive information. In this scenario, a student discovers a Vulnerability exposing the marks and contact details of 20,000 Students without permission.

Legal Provisions Under IT Act, 2000:

1. Section 43 - Unauthorized access:

Deals with Unauthorized access to computer Systems and data.

Copying, downloading or extracting data without permission may attract liability.

The affected organization may claim compensation.

2. Section 66 - Computer Related offences:

Applies when acts covered under section 43 are committed dishonestly or fraudulently.

Punishment may include imprisonment upto
fine up to ₹5 lakh or both.

3. Section 66C - Identity Theft:
Deals with fraudulent use of another person's password or electronic identity.

4. Section 72A - Disclosure of Information:
Deals with disclosure of personal information in breach of a lawful contract under specified conditions.

Types of Vulnerability Disclosure:-

1. Full disclosure:
Vulnerability details are published publicly.
Creates awareness about security weakness.
Risk: Attackers may exploit the vulnerability before it is fixed.

2. Responsible or Coordinated Disclosure:
The vulnerability is privately reported to organization.
Gives the organization time to fix the problem.
Public disclosure is coordinated after remediation.

3. Bug Bounty programme:
Organizations invite security researchers to identify vulnerabilities.
Valid findings may receive monetary rewards.
Testing must follow the programme's rules and scope.

Recommended Disclosure Process:

1. Stop further unauthorized testing immediately.
2. Do not download, copy or publish student information.
3. Report the vulnerability privately to the university's security team.
4. Provide minimum evidence and explain the possible impact.

3. a) Phases of Ethical hacking methodology and Rules of engagement.

Phases of Penetration Testing:

1. Reconnaissance: Collect information about the target system.
2. Scanning: Identify open ports, services and vulnerabilities.
3. Gaining Access: Check whether access can be maintained.
4. Reporting: Document findings, risks and solutions.

Rules of Engagement:

Scope: Specify permitted targets and systems.

Time window: Mention testing dates and timings.

Prohibited techniques: Avoid harmful activities such as data deletion.

Allowed techniques: List permitted testing methods.

Point of contact: Identify the person to contact during testing.

b) Passive and Active footprinting. WHOIS, nslookup / dig

Types of footprinting:

1. Passive footprinting:

collects public information without directly interacting with target systems.

Example: Search engines.

2. Active Footprinting:

Directly interacts with target systems.

Example: DNS queries and network Scanning.

Footprinting Tools:

1. WHOIS: Find domain registration details and name servers.

Risk: Information may be used for phishing.

2. nslookup / dig: Finds IP addresses and DNS records.

Risk: Reveals server information.

Example: nslookup retail co. example.

3. Search - Engine Operators:

- Site: - searches a particular website.
- filetype: - Finds specific file formats.
- intitle: searches words in page titles.

Examples:-

Site: retail co. example

site: retail co. example filetype: pdf

Site: retail co. example intitle: login.

Risk: May reveal confidential documents and login pages.

Explain DNS Zone transfer, its working, risks and Countermeasures.

Introduction:

DNS converts domain names into IP addresses. DNS Zone transfer copies DNS records from a primary server to a secondary server.

Types:

1. AXFR: Transfers the complete DNS zone.
2. IXFR: Transfers only modified DNS records.

Working:

1. Primary server stores DNS records.
2. Secondary server requests a transfer.
3. Primary server checks authorization.
4. DNS records are transferred.
5. Secondary server updates its records.

Analysis of DNS Records:

DNS Record	Information Revealed	Security Risk
www-A	Web Server IP: 203.0.113.10	Identifies web server.
VPN-A	VPN IP: 203.0.113.25	Reveals remote access.
hr-portal-A	Internal IP: 10.10.5.20	Exposes internal systems
dev-db-A	Internal IP: 10.10.8.15	Reveals db location.
mail-MX	Mail server priority.	Helps target email infrastructure.

Security Risks:

Reveals internal network structure.

Identifies important servers.

Helps attackers plan targeted attacks

Exposes infrastructure details.

Countermeasures:

Restrict Zone transfers to authorized secondary DNS servers

Use TSIG authentication for secure transfers.

Implement split-horizon DNS.

Regularly monitor DNS logs.

---

5) Social Engineering Attacks:

Types of Attacks:

1. Phishing: Fake IT email asking users to verify their passwords.
2. Vishing: Phone caller requesting an OTP.
3. Tailgating: Visitor follows an employee through a secured door.
4. Pretexting: Attacker uses a false identity or story to gain trust.

Psychological principles:

Authority: Pretending to be an IT administrator.

Urgency: Creating pressure to act quickly.

Trust: Gaining confidence through a false identity.

Fear: Threatening account suspension.

Curiosity: Encouraging users to open suspicious links.

Social Engineering Assessment Plan:

1. Obtain written authorization.
2. Define the testing scope.
3. Prepare controlled phishing emails and phone scenarios.
4. Conducts tests without causing harm.
5. Record employee responses.
6. Prepare a report with findings.
7. Recommend security improvements.

Countermeasures:

Technical:

use multi-factor authentication.

Apply email filtering and spam protection.

use access control systems.

Procedural:

Verify identity before sharing information.

Follow visitor registration procedures.

Never share passwords or OTPs.

Awareness:

Conduct regular security training.

Teach employees to identify suspicious emails and calls.

Conduct awareness campaigns.